Projet 1 — Active Directory dans Azure et monitoring SOC

Guide des étapes, des outils et de leur importance — Emmanuel Avocetien, octobre 2026

1. Vue d'ensemble

Ce projet reproduit, à petite échelle, ce qu'une équipe TI et une équipe de sécurité font en entreprise : héberger un annuaire d'identités (Active Directory), contrôler qui peut accéder à quoi, puis **surveiller, détecter et documenter** les menaces. Le lab, hébergé dans Azure, a subi une vraie attaque par force brute (environ 40 000 tentatives de connexion RDP) causée par une règle réseau trop ouverte. Elle a été détectée, investiguée et contenue sans compromission.

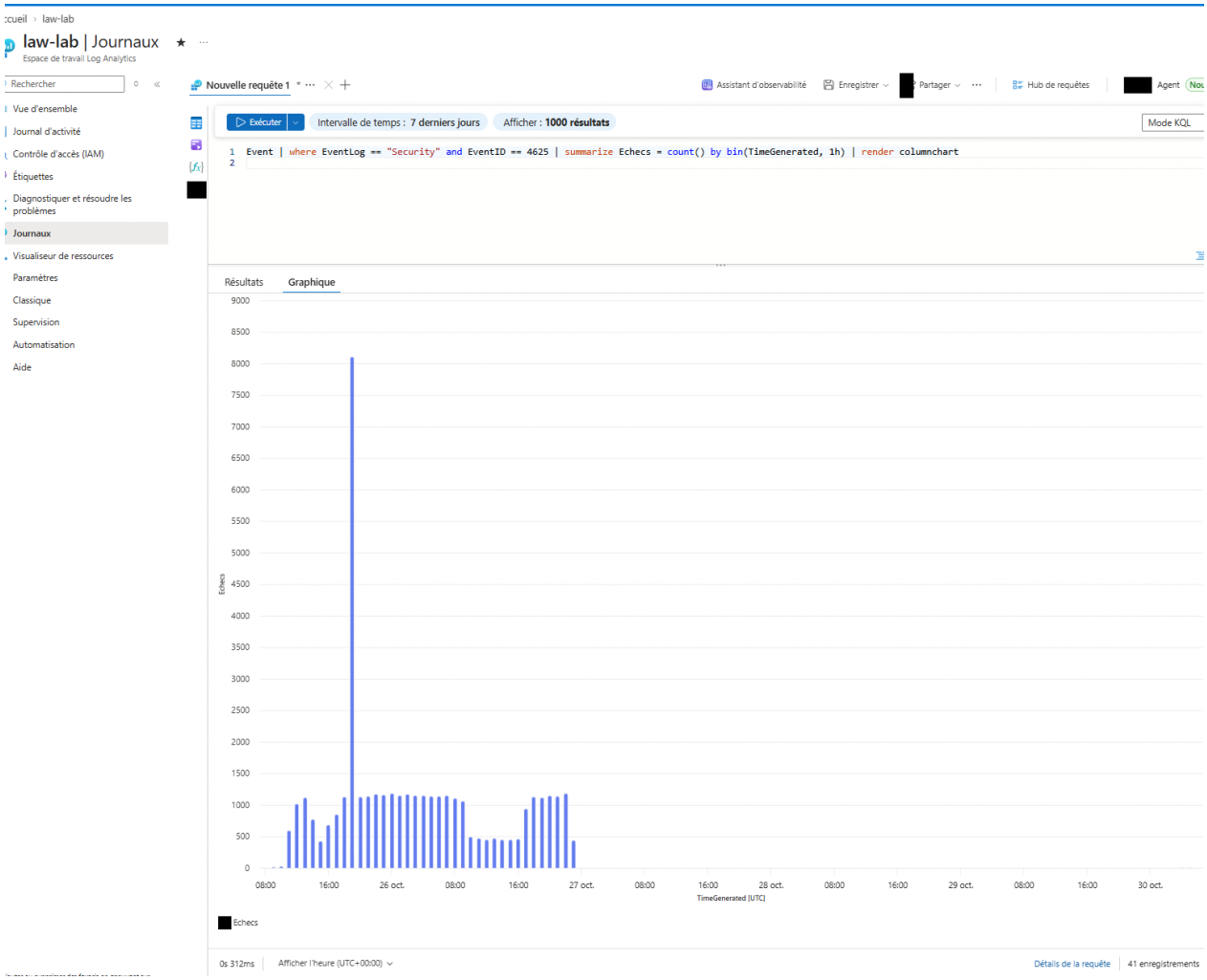
Étape	Outil	Ce que ça fait	Pourquoi c'est important
1. Environnement	Azure : groupe de ressources, réseau virtuel, VM, NSG, alerte de budget	Héberge deux serveurs Windows Server 2022 dans un réseau isolé, avec un pare-feu (NSG) et un plafond de dépenses	Même base qu'une infrastructure d'entreprise ; un réseau mal configuré est la première cause d'incidents cloud
2. Domaine	Active Directory Domain Services, DNS	Crée l'annuaire central *lab.local* : comptes, groupes, authentification Kerberos	L'annuaire est la cible n°1 des attaquants : qui contrôle l'AD contrôle l'entreprise
3. Structure et utilisateurs	PowerShell, unités d'organisation (OU), groupes de sécurité	Automatise la création d'OU, de groupes par rôle et de comptes, avec mot de passe saisi de façon sécurisée	L'automatisation évite les erreurs et rend la gestion des identités (IAM) reproductible et auditable
4. Accès par groupe	Groupes AD, groupe local « Utilisateurs du Bureau à distance »	Donne l'accès RDP à un **groupe**, pas à des individus ; test de refus sur le contrôleur de domaine	Principe du **moindre privilège** : chaque compte n'a que les droits nécessaires, ce qui limite les dégâts d'une compromission
5. Journal local	Observateur d'événements, Get-WinEvent	Lit le journal de sécurité : 4625 (échec), 4624 (succès), 4720 (compte créé)	Première source de preuves d'un analyste ; permet de reconstituer ce qui s'est passé
6. Journalisation cloud	Log Analytics, agent Azure Monitor, règle de collecte (DCR), filtre XPath, KQL	Centralise les événements des deux serveurs et permet de les interroger	Sans centralisation, on ne voit rien à grande échelle ; le filtre XPath limite les coûts
7. Flux réseau	Journal de flux de VNet, Traffic Analytics	Enregistre les connexions autorisées et refusées dans le réseau	Révèle qui tente de se connecter et d'où ; les journaux de flux de NSG disparaissent le 30 sept. 2027
8. Incident	KQL, MITRE ATT&CK, rapport d'incident	Détecte le pic d'échecs, identifie les IP et comptes visés, prouve l'absence de connexion externe réussie, restreint le NSG	Le cycle détection, investigation, confinement, remédiation est le cœur du métier SOC
9. Posture cloud	Microsoft Defender for Cloud (CSPM fondamental, gratuit)	Évalue la configuration de l'abonnement : score de sécurité et recommandations	Repère les mauvaises configurations avant qu'elles soient exploitées ; les plans payants n'ont pas été activés pour maîtriser les coûts

2. Les outils en bref

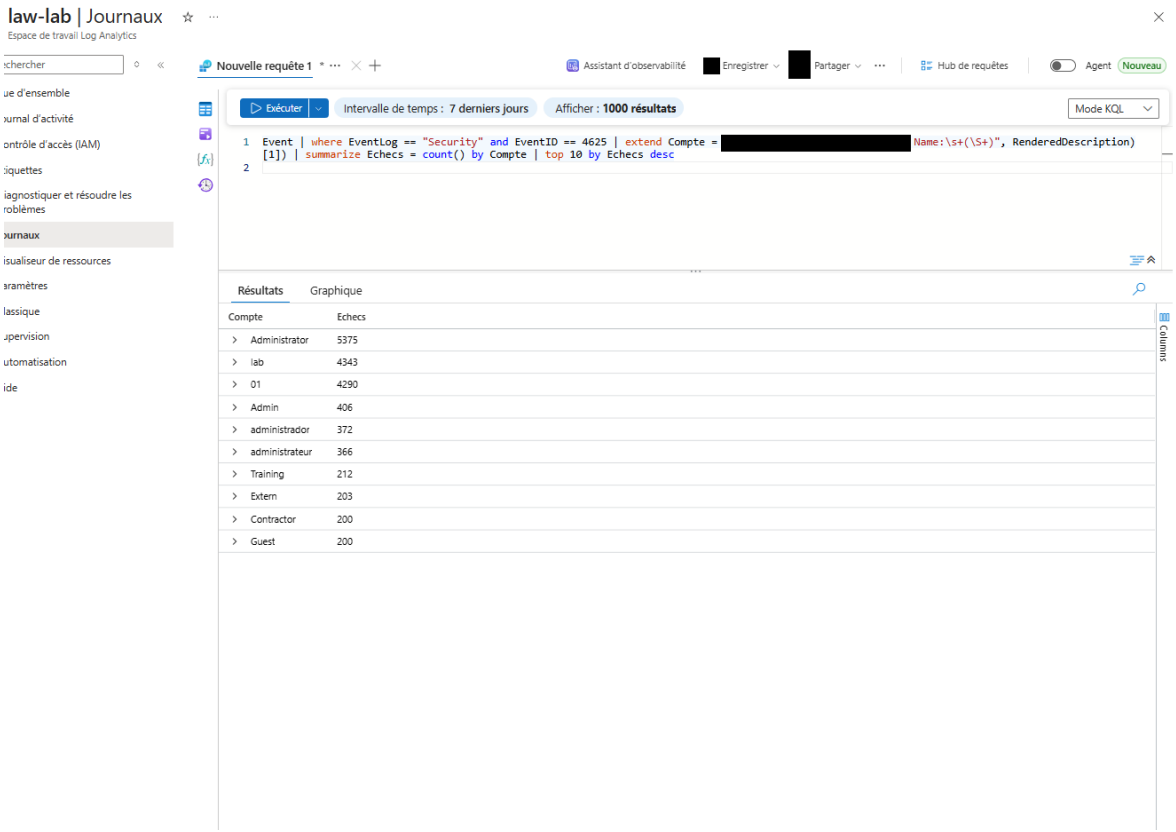
Outil	Description simple
Azure NSG	Pare-feu au niveau réseau : liste de règles qui autorisent ou refusent le trafic (ici, le RDP sur le port 3389).
Active Directory (AD DS)	Annuaire Microsoft qui centralise les identités et les droits d'accès des utilisateurs et des machines.
RDP (bureau à distance)	Protocole pour contrôler un serveur à distance ; très attaqué lorsqu'il est exposé à Internet.
Événements 4624 / 4625 / 4720	Journaux Windows : connexion réussie, connexion échouée, création de compte.

Outil	Description simple
Log Analytics et KQL	Base de données de journaux dans Azure et son langage de requête, comparable au SPL de Splunk.
Règle de collecte (DCR)	Définit quelles données une VM envoie à Log Analytics, avec un filtre pour réduire le volume et le coût.
Defender for Cloud (CSPM)	Contrôle la posture de sécurité : mauvaises configurations, score et recommandations.
MITRE ATT&CK	Catalogue des techniques d'attaque ; ici T1110 (force brute) et T1133 (services distants externes).

3. Preuve de l'incident



Le graphique montre environ 1 000 échecs par heure tant que le RDP était ouvert à Internet, avec un pic d'environ 8 000 en une heure. Les IP principales (93.123.109.204, 217.60.237.10, 77.90.185.6) cumulent plus de 39 000 tentatives. Les comptes visés étaient des noms génériques (Administrator, Admin, administrador, administrateur, Guest). Seules mes propres connexions ont réussi : **0 compromission**.



4. Pourquoi tout cela compte

Pour la sécurité : une règle ouverte à « Any » a été attaquée en quelques heures. La journalisation a permis de prouver ce qui s'est passé et ce qui ne s'est pas passé, ce qu'exige une enquête ou un audit.

Pour le moindre privilège : les droits donnés par groupe et le refus testé sur le contrôleur de domaine montrent que la compromission d'un compte de support n'ouvre pas l'accès à l'annuaire.

Pour les coûts : alerte de budget, filtre XPath, plans payants désactivés, VM arrêtées entre les séances.

Pour la carrière : le projet couvre des savoir-faire de CompTIA Security+ (gestion des identités, journalisation, réponse à incident), de CCNA (réseau, filtrage, flux) et de RHCSA (administration et automatisation de systèmes).

5. Limites et suite

Les VM ont été arrêtées entre les séances, donc l'absence d'attaque du 27 au 30 octobre ne prouve pas seule l'effet de la correction. La réévaluation de Defender for Cloud n'était pas disponible à la publication (VM arrêtées entre les séances). Suites prévues : verrouillage de compte, Azure Bastion ou accès JIT, MFA, alerte Sentinel, puis ingestion des journaux dans Splunk (projet 4).